

APT10 Attack Analysis Report

Prepared by: Solomon Mwaura
Date: February 11, 2026

This section covers step 1 of the lab instructions.

1. Define the Threat Scenario

The organization, a biotechnology firm specializing in cancer research, was targeted by APT10 (also known as Stone Panda or MenuPass), a Chinese state-sponsored threat group notorious for intellectual property theft. The objective was to exfiltrate experimental data and drug formulations.

The attack began with a spearphishing email containing a malicious Excel document. Upon opening, the document executed a macro that leveraged PowerShell to download a Remote Access Tool (RAT). The attackers then performed credential dumping to obtain administrator privileges, moved laterally via RDP to secure research servers, compressed sensitive data into ZIP archives, and exfiltrated the stolen intellectual property to an external Command and Control (C2) server over an encrypted channel.

This section covers content for steps 2, 3, and 5 of the lab instructions.

2. Map to MITRE ATT&CK Tactics and Identify Techniques

Tactic	Technique Name	Technique ID	Description	IOCs
Initial Access	Phishing: Spearphishing Attachment	T1566.001	Adversary sent an email with a malicious Excel file containing a macro payload to gain initial entry.	• File Name: financial_report_2024.xlsm
Execution	Command and Scripting Interpreter: PowerShell	T1059.001	A PowerShell script was triggered by the malicious macro to download and execute a RAT from a remote internal IP.	• URL: hxxp://192.168.50.10/ratscript.ps:1 • Process: powershell.exe
Credential Access	OS Credential Dumping: LSASS Memory	T1003.001	Attackers used a tool to dump the memory of the LSASS process to harvest cleartext credentials or hashes.	• File Path: C:\Windows\Temp\dump.dat

Tactic	Technique Name	Technique ID	Description	IOCs
Lateral Movement	Remote Services: Remote Desktop Protocol	T1021.001	Compromised administrator credentials were used to access the secure research server via RDP.	- Source IP: 192.168.100.20 - Dest IP: 10.30.40.50
Collection	Archive Collected Data: Archive via Utility	T1560.001	Sensitive data was compressed into a ZIP archive to prepare for exfiltration and minimize detection.	File Type: zip archives (inferred context)
Exfiltration	Exfiltration Over C2 Channel	T1041	The archived data was sent to an external C2 server over an encrypted HTTPS connection on a non-standard port.	- Domain: biotechsecure-update.com - Port: 8443 - Protocol: HTTPS

This section covers content for step 4 of the lab.

3. Technique Analysis

Spearphishing Attachment (T1566.001)

- **How it works:** Attackers send emails with malicious attachments (Word, Excel) to specific targets.
- **Execution:** User opens financial_report_2024.xlsm → Enables Content (Macros) → Malicious VBA code executes.
- **APT10 Behavior:** APT10 frequently targets healthcare and manufacturing sectors using industry-relevant document themes to trick users.

Command and Scripting Interpreter: PowerShell (T1059.001)

- **How it works:** PowerShell is a legitimate Windows administration tool used by attackers to execute commands and download payloads without writing files to disk (fileless malware).
- **Execution:** Macro calls powershell.exe → Script connects to 192.168.50.10 → RAT is downloaded and run.
- **APT10 Behavior:** Known for using PowerShell heavily to evade traditional antivirus that trusts system tools.

OS Credential Dumping: LSASS Memory (T1003.001)

- **How it works:** Tools like Mimikatz interact with the Local Security Authority Subsystem Service (LSASS) to read password hashes or cleartext credentials stored in memory.

- **Execution:** Attacker runs dumping tool → Memory saved to C:\Windows\Temp\dump.dat → Credentials extracted for reuse.
- **APT10 Behavior:** Credential theft is a standard procedure for APT10 to facilitate lateral movement across the network.

Remote Services: Remote Desktop Protocol (T1021.001)

- **How it works:** Attackers use valid credentials to log into remote systems via RDP, blending in with legitimate administrator traffic.
- **Execution:** Attacker on compromised host 192.168.100.20 → Connects to Target 10.30.40.50 → Gains GUI access to research data.
- **APT10 Behavior:** Often relies on RDP for lateral movement once credentials are secured, as it allows full interactive control.

Exfiltration Over C2 Channel (T1041)

- **How it works:** Data is sent directly to the adversary's command and control infrastructure, often encrypted to look like normal web traffic.
- **Execution:** Data zipped → Connection established to biotechsecure-update.com:8443 → Data uploaded.
- **APT10 Behavior:** Uses "imposter" domains (typosquatting legitimate names) and encryption (SSL/TLS) to hide data theft in plain sight.

This section covers the content from step 6 of the lab.

4. Mitigation Strategies

Technique ID	Mitigation Strategy	Justification	Potential Drawback
T1566.001 T1059.001	Disable Office Macros by Default PowerShell Constrained Language Mode	Blocking macros from internet-originated files breaks the initial infection vector immediately. Restricts PowerShell to a limited set of commands, preventing the execution of complex malicious APIs used by RATs.	May disrupt legitimate business workflows for finance/HR teams that rely on complex macro-enabled spreadsheets. Can break legitimate IT administration scripts if they are not digitally signed and approved.

Technique ID	Mitigation Strategy	Justification	Potential Drawback
T1003.001 T1021.001	Enable Windows Defender Credential Guard Network Segmentation & RDP Restrictions	Virtualizes the LSASS process, making it inaccessible to tools like Mimikatz even if the attacker has Admin rights. Placing research servers in a restricted VLAN and allowing RDP only from specific "Jump Hosts" limits attacker reach.	Requires specific hardware (CPU virtualization extensions) and may be incompatible with some older third-party security agents. Increases friction for legitimate administrators who must follow a stricter login process to manage servers.
T1041	Web Proxy & Domain Reputation Filtering	Blocking connections to uncategorized or newly registered domains (like the C2 URL) prevents data from leaving the network.	Risk of false positives blocking access to legitimate new websites or partner portals.

This section covers the content from step 7 of the lab.

5. Monitoring and Validation

1. Initial Access & Execution (Phishing/PowerShell):

- **Validation:** Use "Atomic Red Team" tests (Test T1566.001) to simulate a macro execution that spawns PowerShell.
- **Monitoring:** Configure SIEM to alert on Process Creation events where excel.exe is the parent process of powershell.exe. Monitor for PowerShell scripts attempting to download files from internal IP addresses (Indicator: 192.168.50.10).

2. Credential Access (Dumping):

- **Validation:** Attempt to run a safe version of Mimikatz or procdump against the LSASS process in a test environment to verify if Credential Guard blocks it.
- **Monitoring:** Enable File Integrity Monitoring (FIM) on C:\Windows\Temp\ and C:\Users*\AppData\Local\Temp\ to alert on the creation of suspicious file extensions like .dmp or .dat (Indicator: dump.dat).

3. Lateral Movement (RDP):

- **Validation:** Attempt RDP connections from a non-admin workstation to the secure research server VLAN to ensure the firewall drops the connection.
- **Monitoring:** Ingest Windows Event Logs (Event ID 4624 - Successful Logon). Create a correlation rule to alert on RDP logons (Logon Type 10) to critical servers (10.30.40.50) originating from standard workstation subnets (192.168.100.x).

4. Exfiltration (C2 Traffic):

- **Validation:** Attempt to connect to a test external domain on port 8443 to see if the proxy allows the traffic.
- **Monitoring:** Monitor network egress logs for high-volume data transfers to uncategorized domains. Specifically, alert on outbound traffic on Port 8443 (Indicator: biotechsecure-update.com) that exceeds a standard size threshold.